

Cyber Threat Intelligence

Executive Briefing

Report Date: July 06, 2026

Generated: 2026-07-06 15:06 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	11	4	1	20

2. Executive Summary

As of July 06, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, comprised of 4 Critical, 11 High, 4 Medium, and 1 Low severity findings. The current organizational risk posture is categorized as 'High' according to CVSS v3.1 metrics, necessitating immediate remediation to maintain internal data integrity. CVE-2026-49360, identified as Unauthorized Database Operations in Recce Server, represents the primary threat due to its potential for unauthenticated raw SQL execution, which poses an unacceptable risk of comprehensive data exfiltration. The recommended response posture is an immediate emergency maintenance window to apply identified patches and implement compensating network controls. Failure to remediate these vulnerabilities within the designated cycle will significantly elevate our exposure to targeted exploitation.

3. Critical Action List

- CVE-2026-49360: Immediately disable the Recce server DuckDB integration interface and deploy vendor-supplied SQL restriction patches within 4 hours.
- CVE-2026-49352: Initiate an emergency rotation of all 9router JWT secrets and update the authentication module to utilize a secure, environment-injected key within 6 hours.
- CVE-2026-54617: Apply immediate input validation patches to the LaunchServer FileServerHandler and isolate the service from the external perimeter within 8 hours.
- CVE-2026-52830: Implement strict path sanitization filters on the fast-mcp-telegram service and revoke all existing bearer tokens within 12 hours.
- CVE-2026-50194: Reconfigure Steeltoe management-port network policies to enforce host-header validation and block spoofing attempts within 24 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-49360	Unauthorized Database Operations ...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	Authentication Bypass via Hardcod...	9.8	Critical	88/100	CWE-798
CVE-2026-54617	Path Traversal in LaunchServer Fi...	9.8	Critical	88/100	CWE-22
CVE-2026-52830	Bearer Token Path Traversal in Te...	9.4	Critical	85/100	CWE-22
CVE-2026-50194	Management Port Isolation Bypass	8.2	High	74/100	CWE-288
CVE-2026-2092	SAML Assertion Validation Error i...	7.7	High	69/100	CWE-1287
CVE-2026-49353	Host Header Spoofing in 9router	7.5	High	68/100	CWE-290
CVE-2026-46599	Resource Exhaustion in TIFF Decom...	7.5	High	68/100	CWE-770
CVE-2026-52792	Source Disclosure via NTFS Filena...	7.5	High	68/100	CWE-69
CVE-2026-50200	Sensitive Information Leakage in ...	7.5	High	68/100	CWE-200
CVE-2026-50196	Registry Poisoning in Steeltoe Di...	7.5	High	68/100	CWE-20
CVE-2026-49289	XPath Denial of Service in Simple...	7.5	High	68/100	CWE-400
CVE-2026-52829	Memory Corruption in Zebra Addres...	8.6	High	68/100	CWE-617
CVE-2026-52834	Integer Overflow in jxl-grid	8.6	High	66/100	CWE-122
CVE-2026-49284	SAML Response Validation Bypass	8.2	High	64/100	CWE-345
CVE-2026-50201	Insecure Permission for Sensitive...	6.5	Medium	59/100	CWE-269
CVE-2026-50202	Insecure JWKS Caching in Steeltoe	5.9	Medium	53/100	CWE-668
CVE-2026-50267	Insecure Storage of TLS Keys in S...	4.7	Medium	42/100	CWE-312
CVE-2026-49292	Exposure of Database Initializati...	4.8	Medium	28/100	CWE-862
CVE-2026-50268	Cryptographic Padding Mismatch in...	1.9	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49360

Finding: Unauthorized Database Operations in Recce Server

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1505, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server's DuckDB integration interface fails to restrict raw SQL execution commands for unauthenticated users. This lack of access control allows an attacker to interact directly with the underlying database driver. The

vulnerability results in unauthorized local file read and write operations, enabling full system compromise.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted SQL command via the Recce server interface. The server passes the payload directly to the DuckDB engine without verifying administrative credentials. The engine executes the command, granting the attacker the ability to read arbitrary configuration files or write malicious web shells. This leads to complete control over the application environment.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-49352

Finding: Authentication Bypass via Hardcoded JWT Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The 9router application utilizes a hardcoded fallback secret key for signing JSON Web Tokens (JWT) used for session management. The lack of dynamic key generation and proper configuration management allows attackers to predict valid authentication tokens. This vulnerability enables unauthenticated parties to forge administrative sessions and gain full access to the system.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the default JWT secret through reverse engineering of the 9router binary or leaked documentation. The attacker generates a new session token, signing it with the discovered secret key to impersonate an administrator user. By presenting this forged token in the Authorization header, the attacker successfully bypasses the authentication gate. This grants the attacker full administrative privileges within the system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: Path Traversal in LaunchServer File Handler

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1083, T1040

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The LaunchServer FileServerHandler function improperly validates file path inputs from client requests, failing to sanitize directory traversal sequences. This root cause allows for absolute path navigation outside of the intended web root directory. Consequently, unauthenticated remote attackers can read or potentially write sensitive system files with application service permissions.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP GET request to the file server endpoint with a path parameter containing '..' sequences. The FileServerHandler fails to sanitize the path, resolving it to sensitive locations like '/etc/passwd' or system configuration files. The server then returns the requested file content back to the client. This results in the unauthorized disclosure of sensitive data and potentially enables further system exploitation.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Bearer Token Path Traversal in Telegram MCP

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official

MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram service improperly validates path parameters when handling bearer tokens, resulting in a directory traversal vulnerability. The root cause is a failure to sanitize input tokens before using them to access session-related storage files. This allows an attacker to bypass Telegram session protections and potentially access session data belonging to other users.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the Telegram service using a crafted bearer token path parameter containing '..' sequences. The service fails to validate the requested path, resolving it to restricted session files on the underlying filesystem. The service then returns the sensitive session metadata associated with that path. This allows the attacker to hijack active Telegram sessions belonging to legitimate users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-50194

Finding: Management Port Isolation Bypass

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe framework exhibits a vulnerability where management-port isolation is bypassed via spoofed Host headers in HTTP requests. The root cause is a failure to bind management endpoints to dedicated internal interfaces or verify the request host before granting access. This flaw permits external access to restricted administrative ports that are intended for internal-only use.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request to the application's management port with a crafted Host header designed to bypass internal network logic. The application incorrectly evaluates the request context and accepts the connection, thinking it originates from a trusted internal source. The attacker now has access to sensitive management functionality, such as configuration management or health check endpoints. This leads to the exposure of internal system settings and potential configuration modification.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092

Finding: SAML Assertion Validation Error in Keycloak

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Keycloak fails to properly validate encrypted SAML assertions, allowing for potential unauthorized access. The root cause is improper signature and encryption validation checks that allow an attacker to substitute or manipulate the assertion content. This vulnerability permits an attacker to assume the identity of another user in the system.

Proof of Concept (PoC):

An authenticated user with low privileges captures a SAML authentication message. The user modifies the encrypted assertion elements to change the identity of the claim, leveraging the lack of strict validation in the assertion handling module. Keycloak decrypts and accepts the altered assertion without verifying its original signature integrity. The user effectively escalates their privileges to those of the targeted account.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: Host Header Spoofing in 9router

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

The 9router gateway component performs insufficient validation on incoming HTTP Host headers when enforcing local-only access restrictions. The root cause is a reliance on mutable request headers for security boundaries instead of network-level source verification. This failure allows remote attackers to bypass access controls and interact with internal management endpoints.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request to the 9router interface with a spoofed 'Host: localhost' header. The application processes the request as if it originated from a trusted internal source. This allows the attacker to reach restricted configuration pages that should be protected from external traffic. The attacker successfully gains unauthorized visibility into sensitive device settings.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: Resource Exhaustion in TIFF Decompression

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
---------------	---------	-------------------	-----

Privileges Required	None
Scope	Unchanged
Integrity Impact	None

User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The golang.org/x/image/tiff library utilizes an inefficient PackBits decompression algorithm that lacks sufficient memory allocation constraints. When processing a malformed TIFF image, the library attempts to allocate massive buffers based on deceptive metadata headers. This leads to a denial of service condition by crashing the application through excessive resource consumption.

Proof of Concept (PoC):

An unauthenticated remote attacker uploads a maliciously crafted TIFF file to a server using the golang.org/x/image/tiff library. The library's decompression function reads the attacker-supplied PackBits metadata and initiates a memory allocation far exceeding available system capacity. The runtime environment terminates the process, resulting in a denial of service for all users of the affected application.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

CVE-2026-52792

Finding: Source Disclosure via NTFS Filename Manipulation

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Algernon server exhibits a vulnerability on Windows platforms where specific NTFS filename character encodings allow access to server-side source code files. The issue arises from how the underlying filesystem handles special character mappings when accessed via web requests. This failure leads to the disclosure of sensitive application logic, potentially exposing secrets or vulnerabilities to unauthorized users.

Proof of Concept (PoC):

An unauthenticated remote attacker probes the Algernon web server with request paths containing NTFS-specific alternate data streams or character sequences. The server interprets these requests as file access operations instead of script execution commands, bypassing the intended execution logic. The server returns the raw source code of the requested script to the attacker. This results in the complete exposure of sensitive application logic and credentials.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>

CVE-2026-50200

Finding: Sensitive Information Leakage in Env Sanitizer

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe environment sanitizer fails to filter embedded database connection strings, causing the disclosure of plain-text passwords in management endpoints. The root cause is an incomplete regex or parsing logic in the sanitization routine that misses specific connection string formats. This vulnerability enables unauthenticated attackers to steal database credentials from diagnostic endpoints.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the application's diagnostic /env endpoint. The framework renders the current environment configuration, including sensitive connection strings that the sanitizer missed. The attacker parses the output to identify embedded database usernames and passwords. This allows the attacker to gain unauthorized direct access to the backend database infrastructure.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Registry Poisoning in Steeltoe Discovery

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Steeltoe.Discovery.Eureka component improperly handles unrecognized DataCenterInfo.Name values, which leads to the corruption of the entire registry fetch process. The root cause is a lack of input validation on service metadata during the registration and synchronization process. This allows an attacker to cause a denial-of-service condition for all services relying on the registry.

Proof of Concept (PoC):

An unauthenticated remote attacker registers a new service with the Eureka server using a malicious DataCenterInfo.Name value. The Steeltoe client processes this malicious metadata, which triggers an error or unhandled state that disrupts the registry synchronization queue. Consequently, all legitimate services attempting to fetch registry updates fail. This results in a widespread service discovery denial-of-service condition across the infrastructure.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: XPath Denial of Service in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial-of-service attack due to improper processing of XML payloads involving complex XPath transforms. The root cause is the lack of limits on recursion depth and computational complexity during the XPath evaluation process. This enables an attacker to consume excessive CPU and memory resources by submitting small but cryptographically heavy XML payloads.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted SAML request containing deep nested XML structures to the SimpleSAMLphp interface. The server's XML parser triggers expensive XPath transforms to process the input. The CPU load spikes to 100% as the server attempts to resolve the complex path definitions, leading to a denial of service. The application becomes unresponsive to all other legitimate requests.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Memory Corruption in Zebra Address Book

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The Zebra Address Book service contains a memory management error when processing IPv4-mapped addresses during a mempool update. The root cause is an improper handling of address type conversion that leads to a buffer overflow during memory allocation. This vulnerability can be leveraged by a remote attacker to cause an application abort, leading to denial of service or potential remote execution.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a network request containing a malformed IPv4-mapped address to the Zebra Address Book update endpoint. The service attempts to process the address and perform a mempool update, triggering a memory consistency error due to incorrect input handling. The process encounters a fatal failure and aborts immediately, resulting in a denial of service. If precisely crafted, this memory corruption may allow for further exploitation of the service's memory space.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>

CVE-2026-52834

Finding: Integer Overflow in jxl-grid

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The jxl-grid library on 32-bit platforms contains an integer overflow error during image grid calculations, leading to an incorrect buffer size allocation. The root cause is a lack of bounds checking on input dimensions, which causes an out-of-bounds write during grid memory operations. This memory corruption can lead to application crashes or potential arbitrary code execution by a remote attacker.

Proof of Concept (PoC):

An unauthenticated remote attacker provides a malformed image payload with extreme grid dimensions to an application using jxl-grid. The library calculates an offset based on these dimensions, causing an integer overflow on 32-bit architectures. This leads to memory being overwritten outside the intended grid buffer boundaries. The application crashes, and in certain conditions, the attacker can hijack control flow.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

CVE-2026-49284

Finding: SAML Response Validation Bypass

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The SimpleSAMLphp SP component accepts forged SAML responses due to a logical mismatch between unsigned Response/InResponseTo and signed assertion validation routines. The root cause is the improper handling of SubjectConfirmationData during the verification process, allowing attackers to mix and match parts of assertions. This vulnerability allows an unauthenticated attacker to bypass authentication by masquerading as a legitimate identity provider.

Proof of Concept (PoC):

An unauthenticated remote attacker captures a legitimate SAML authentication response and modifies the assertions to bypass intended security checks. By presenting a combination of an unsigned Response and a signed assertion missing specific constraints, the attacker tricks the SP into validating the payload. The system authenticates the attacker as a trusted user. This leads to complete account takeover and unauthorized access to application resources.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>

CVE-2026-50201

Finding: Insecure Permission for Sensitive Actuators

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269

Score Provenance: CNA Official

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe framework restricts access to sensitive management endpoints, such as /heapdump and /env, to users with a 'Restricted' role, which is insufficiently permissive for such critical features. The root cause is an improper

authorization model that fails to enforce the principle of least privilege on diagnostic tools. This vulnerability allows lower-privileged users to extract critical runtime environment information.

Proof of Concept (PoC):

A user with the low-privileged 'Restricted' role makes an HTTP request to the /heapdump or /env endpoints of a Steeltoe-powered service. The application checks the authorization layer, confirms the 'Restricted' role exists, and serves the requested diagnostic information. The user receives sensitive configuration details, environment variables, or memory dumps. This leads to information leakage and facilitates further targeted exploitation.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-50202

Finding: Insecure JWKS Caching in Steeltoe

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official
MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's static JSON Web Key Set (JWKS) cache is incorrectly shared across different security schemes and fails to implement proper cache invalidation. The root cause is a global cache configuration that does not distinguish between distinct trust domains or authority contexts. This vulnerability allows keys to persist after they should have been revoked, permitting unauthorized authentication.

Proof of Concept (PoC):

An administrative attacker with high privileges updates the JWKS configuration to remove access for a specific service. The Steeltoe application continues to use the cached keys from the global store, failing to invalidate the entries upon update. The attacker or others continue to use the revoked keys to gain access to resources in a different scheme. This results in the compromise of access control boundaries.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-50267

Finding: Insecure Storage of TLS Keys in Steeltoe

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe framework writes sensitive TLS private keys to the /tmp directory with default file permissions that allow for global read access. The failure stems from the use of insecure temporary file creation routines without proper permission restriction or post-usage deletion. This vulnerability allows local attackers to access and steal private keys for TLS-encrypted communications.

Proof of Concept (PoC):

A local attacker with low-level shell access monitors the /tmp directory for the creation of temporary files by the Steeltoe service. When the service initiates a TLS handshake and stores the private key, the attacker reads the contents of the file due to the overly permissive default settings. The attacker then copies the key and uses it to intercept or spoof encrypted communications. This facilitates the compromise of confidential data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-49292

Finding: Exposure of Database Initialization Endpoint

CVSS v3.1 Score: 4.8 | Severity: Medium | Urgency Score: 28/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The Kiwi TCMS /init-db/ page remains accessible and functional after the initial setup phase is completed. This flaw stems from a lack of state verification logic to disable the initialization interface post-deployment. Unauthorized access to this page allows attackers to potentially disrupt or interfere with the application's database state.

Proof of Concept (PoC):

An unauthenticated remote attacker navigates to the /init-db/ endpoint after the platform has been deployed. The server receives the request and renders the database initialization form, ignoring the fact that setup was already finalized. By submitting payloads to this endpoint, the attacker may trigger database re-initialization routines. This causes a loss of service for legitimate users and potential data integrity issues.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

CVE-2026-50268

Finding: Cryptographic Padding Mismatch in Steeltoe

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local
Privileges Required	High
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Steeltoe framework incorrectly defaults to PKCS#1 v1.5 padding even when OAEP settings are specified in the security configuration. The root cause is an implementation error in the encryption provider where the padding flag is silently ignored or overridden. While limited in impact due to the high complexity required, this flaw exposes encrypted data to oracle-based attacks.

Proof of Concept (PoC):

A local user with high privileges manipulates the Steeltoe configuration files to force the system to use the flawed encryption provider. The attacker then observes the ciphertext responses to repeated operations, looking for padding oracle signals. Because the system defaults to PKCS#1 v1.5 instead of OAEP, the attacker can eventually recover sensitive data. This results in the compromise of limited cryptographic information.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>

- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>